MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 042 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD GUIDE · CUI TRANSMISSION

How to Send CUI by Email Without Failing 3.13.8

How to send CUI via email: why default TLS fails 3.13.8, when S/MIME or Purview encryption holds up, and when DoD SAFE is the better road.

BY **PATRICK CARUSO** READING TIME · 7 MIN CUI · EMAIL-ENCRYPTION · NIST-800-171 · DOD-SAFE · FLOW-DOWN

Sending Controlled Unclassified Information by email is permitted, common, and entirely defensible, and most small contractors who do it every week still could not show an assessor why their last message was protected. The problem is not that email is forbidden. It is that the protection most people assume they have - the padlock their mail provider applies between servers - is a best-effort courtesy, and NIST SP 800-171 asks for something you can point to.

Here is the short answer to how to send CUI via email. Requirement 3.13.8 says to "implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards," and 3.13.11 says the cryptography must be FIPS-validated. That leaves three acceptable roads: encrypt the message itself with S/MIME or a message-encryption service running on validated cryptography, enforce TLS to a specific partner and keep the configuration as evidence, or take the file out of email and move it through a purpose-built exchange such as DoD SAFE. Whichever you pick, the recipient must be authorized to hold the CUI and must be protecting it on their side. Each of those clauses is a separate decision, so take them one at a time.

FIELD COPY
ISSUE Nº 042
CUI

3

SPRS POINTS FOR 3.13.8, CRYPTOGRAPHIC PROTECTION OF CUI IN TRANSMISSION

5

SPRS POINTS FOR 3.13.11 - 3 OF THEM LOST EVEN WHEN THE ENCRYPTION IS REAL BUT NOT FIPS-VALIDATED

8 GB

DOD SAFE'S PER-PACKAGE CEILING, ACROSS UP TO 25 FILES, DOWNLOADABLE FOR 7 DAYS

Is TLS enough to send CUI by email?

Not the way it arrives out of the box. Microsoft's own documentation is unusually blunt about this. Exchange Online uses opportunistic TLS by default: it tries the strongest version the receiving server will accept and, if that server offers no TLS at all, sends the message unencrypted. The same page notes that TLS encrypts the connection, not the message, so a message that crossed one encrypted hop can travel the next one in the clear once it is forwarded.

That is the whole difficulty with 3.13.8 when you rely on transport. The 800-171A objectives ask an assessor to determine that the cryptographic mechanisms are identified and then implemented. A mechanism that silently falls back to plaintext for a recipient you did not test is not one you can say was implemented for any given message. You can hope it was. You cannot evidence it.

Enforced TLS changes that. Microsoft describes configuring connectors so that mail to a named partner domain must use a secure connection, with separate connectors for inbound and outbound flow. With that in place the failure mode flips: a message the partner's server cannot receive securely does not go out unprotected. The connector configuration becomes the evidence, scoped to named partners. Two limits keep it from being a complete answer. It covers only the domains you configured, which means the CUI you send to anyone else is back on opportunistic TLS. And it ends at the partner's mail server, so what happens inside their environment is their control, not yours - which is the fourth question below.

Should the message itself be encrypted?

For anything beyond a short list of configured partners, yes, and there are two credible ways to do it.

S/MIME encrypts and signs the message end to end using certificates. Microsoft recommends it where either party requires true peer-to-peer encryption and names business-to-government mail as a common case. The price is

◆ THE PASSPHRASE TAKES ANOTHER ROAD

DoD SAFE does not store the encryption passphrase or send it to recipients. Its help pages put the sender on the hook for sharing it through a separate secure channel, such as encrypted email or a phone call. A passphrase typed into the same email thread as the download notice protects nothing.

administration: you need the public key on file for every recipient, recipients guard their own private keys, and a compromised key means reissuing and redistributing. S/MIME also blinds your own malware and policy scanning to the encrypted content, a trade-off worth writing into the SSP rather than discovering later.

Microsoft Purview Message Encryption takes the opposite trade. It is built on the Azure Rights Management service, admins can apply it automatically through mail flow rules, and recipients outside Microsoft 365 read the message through an encrypted portal after signing in or requesting a one-time passcode. No certificate exchange is needed. But the tenant it runs in matters more than the feature name. Purview encryption in a commercial tenant is still commercial Microsoft 365 holding your CUI, and whether that tenant clears DFARS 252.204-7012's FedRAMP Moderate equivalency bar is the cloud decision MacZine already worked through in the external service provider issue. The encryption button does not settle it. Microsoft also documents that a GCC High sender's protected mail reaches recipients outside GCC High, commercial users included, as a wrapper that sends them to the portal.

Either way, 3.13.11 applies to whatever module performs the encryption. Strong and unvalidated costs 3 of that requirement's 5 SPRS points, and why a certificate number is the only proof is argued in full in our FIPS 140-3 piece.

TLS protects the road between two mail servers. The question 3.13.8 asks is whether you can prove this particular message was protected, and for opportunistic TLS nobody can.

When should the file leave email entirely?

When it is large, when the recipient is a government office, or when you cannot establish encryption with the other side. DoD SAFE, at safe.apps.mil, exists for exactly this, and its rules are more specific than its reputation.

Only authenticated CAC users can start a transfer to any address. A contractor without a CAC is a guest, and per the DoD SAFE help pages a guest can send files only when a CAC holder has first issued a drop-off request, which stays valid for 14 days. So a non-CAC contractor who needs to deliver CUI to a program office asks the government point of contact to send the request, then uploads against it. Packages top out at 25 files and 8 GB, and recipients have 7 days to pull them. The help pages still describe the service's approval in the older FOUO, PII, and PHI vocabulary and require senders of that data to tick "Encrypt every file" and supply a passphrase. Treat that box as mandatory for CUI, and send the passphrase by a different route.

Between two contractors where neither side holds a CAC, DoD SAFE cannot start the transfer at all, which is why a controlled file exchange inside your own boundary is often the cleaner design. MacTech's deployable CUI vault is one such pattern: files move over HTTPS directly into a FIPS-mode boundary, and the application that authorizes the upload never touches the bytes. We would steer you away from treating our own Freehold as the answer here. Its page says plainly that its cryptography is not FIPS-validated, and a tool that candid about its limits should not be pressed into service against 3.13.11.

Who is on the other end?

This is the decision the encryption debate crowds out, and it is the one an encrypted channel cannot make for you. Requirement 3.1.3 asks you to control the flow of CUI in accordance with approved authorizations. A perfectly encrypted message to someone with no contractual basis to hold the information is a well-protected unauthorized disclosure.

Before you send, you should be able to name the contract that authorizes the recipient to receive this CUI, and you should know the environment it lands in is protected. When the recipient is your subcontractor, that knowledge is not optional. DFARS 252.204-7012 paragraph (m) requires the clause to flow down to subcontracts involving covered defense information, and the moment your email arrives, the sub's mailbox, laptop, and file shares are CUI systems carrying the full set of 110 requirements. Emailing a drawing package to a shop that has never heard of 7012 does not keep the CUI out of their scope. It turns their unprepared environment into a CUI environment, and you are the one who put the CUI there.

Mark the message and each attachment before it leaves, following the rules for what makes a file CUI in the first place, so the recipient knows what they are holding. If your honest answer to where CUI goes is "wherever email takes it," that is a boundary problem before it is an encryption problem, and enclave architecture is where to fix it. Pick the channel second. Pick the recipient first, and write down why. ◆